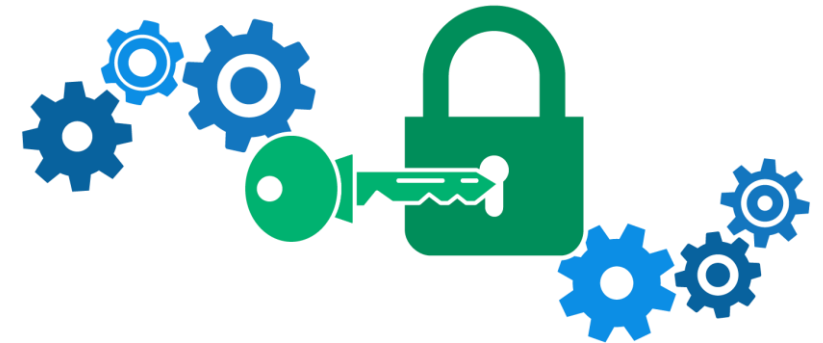




Criptografía

Ing. Javier Toquica

Agenda

1. Panorama de la criptografía
2. Algoritmos de cifrado
3. Intercambio de claves públicas



Panorama de la criptografía

Definición de criptografía

Criptografía:

Del griego «escritura oculta». Es el arte y la ciencia de transformar información en texto plano, mediante cifrado, en una forma intermedia denominada texto cifrado para protegerla durante su almacenamiento o transmisión.

Raíces griegas:

Kryptos: oculto

Graphein: escribir

<http://ciphersbyritter.com/GLOSSARY.HTM#Cryptography>

Panorama de la criptografía

Texto cifrado

El texto cifrado corresponde a la información ininteligible que resulta de aplicar un algoritmo criptográfico al texto plano. Texto cifrado = función del texto plano, la clave y, cuando corresponda, el vector de inicialización

Vector de inicialización

Un vector de inicialización (IV) es un valor de tamaño fijo, normalmente aleatorio o pseudoaleatorio, que permite iniciar ciertos modos de cifrado. Sus requisitos dependen del algoritmo y del modo utilizado.

Panorama de la criptografía

Clave de cifrado

Una clave criptográfica es un valor utilizado por el algoritmo para transformar los datos. Debe generarse y protegerse de forma segura para que solo quien posea la clave correspondiente pueda recuperar el texto plano.

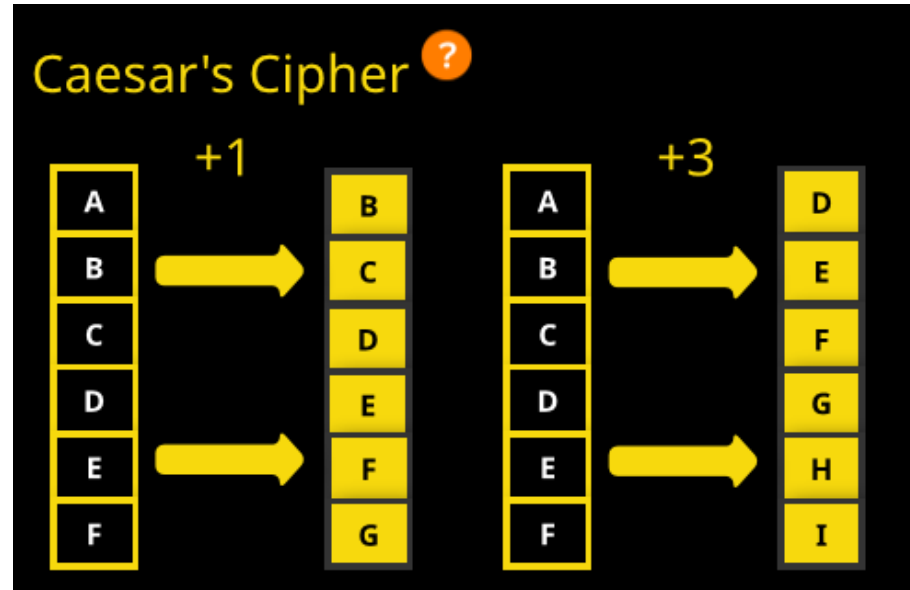
Panorama de la criptografía

Historia de la criptografía

La criptografía posee una historia de miles de años.

- Cifrado César
- Esteganografía
- Guerras mundiales

Panorama de la criptografía



Un sistema de cifrado comprende dos elementos:

Algoritmo: El conjunto de operaciones matemáticas que transforma el texto plano.

Clave: El valor que controla las operaciones de cifrado o descifrado sobre los datos.

Panorama de la criptografía

La esteganografía oculta un archivo, mensaje, imagen o video dentro de otro medio.

Uno de los primeros registros de esteganografía data aproximadamente del 440 a. C., cuando los griegos ocultaban mensajes bajo tablillas de cera.



Panorama de la criptografía

Segunda Guerra Mundial

Ambos bandos utilizaron ampliamente la criptografía durante la Segunda Guerra Mundial. El trabajo inicial de matemáticos polacos y el posterior esfuerzo aliado permitieron descifrar comunicaciones del Eje y obtener una ventaja estratégica.



Panorama de la criptografía

Usos actuales de la criptografía

Después de revisar su historia, estudiaremos los objetivos actuales de la criptografía en los sistemas de información.

- **Privacidad y confidencialidad**
- **Autenticidad**
- **Integridad**
- **No repudio**

Panorama de la criptografía

Confidencialidad

La confidencialidad busca prevenir la divulgación no autorizada de información.

Amenazas a la confidencialidad

Entre las principales amenazas se encuentran:

- Ingeniería social
- Reutilización insegura de medios
- Interceptación de comunicaciones

Panorama de la criptografía

Autenticidad

La autenticidad brinda confianza sobre la identidad del emisor de un mensaje.

¿Por qué importa la autenticidad?

La autenticidad permite verificar el origen atribuido a los mensajes y a sus modificaciones. Puede validarse mediante firmas digitales y códigos de autenticación de mensajes (MAC).

Panorama de la criptografía

Integridad

La integridad permite comprobar que los datos no han sido modificados respecto de su versión original.

Mecanismos para verificar integridad

- Código de autenticación de mensajes (MAC)
- Hash o resumen de mensaje
- Firma digital

Panorama de la criptografía

No repudio

El no repudio se apoya en la integridad y la autenticidad. Brinda evidencia para evitar que el originador de un mensaje niegue su firma sobre el contenido.

¿Cómo se logra?

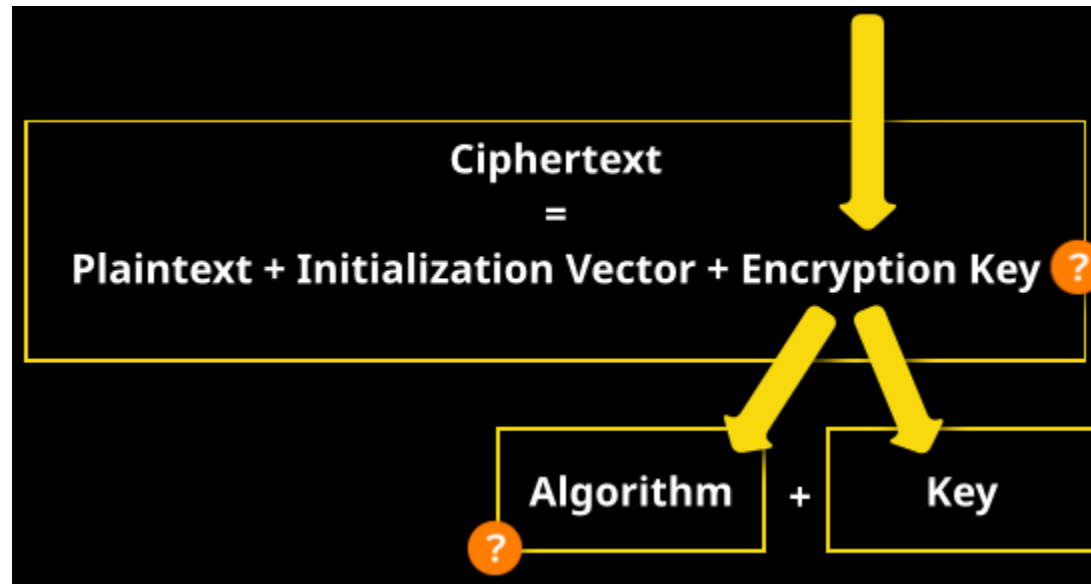
- Mediante firmas digitales.

ENCRYPTION ALGORITHMS

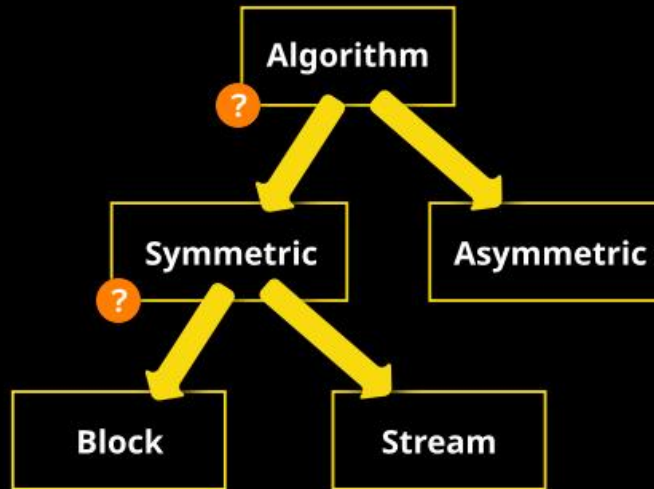
Algoritmos de cifrado

Introducción

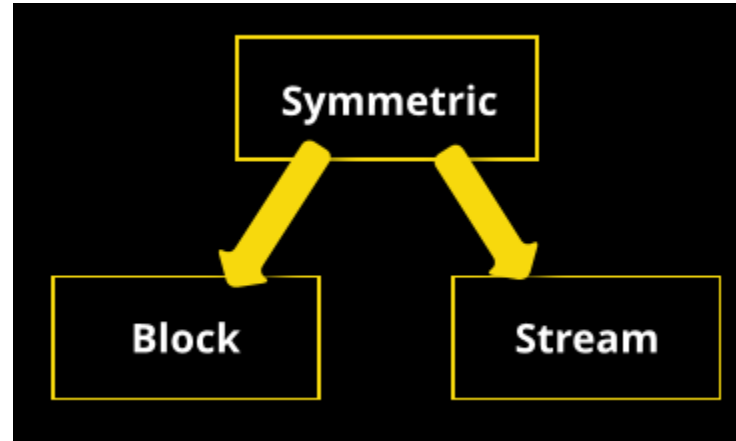
Después de comprender qué es la criptografía, su historia y sus objetivos, revisaremos cómo protege los datos.



Algoritmos de cifrado



Algoritmos de cifrado

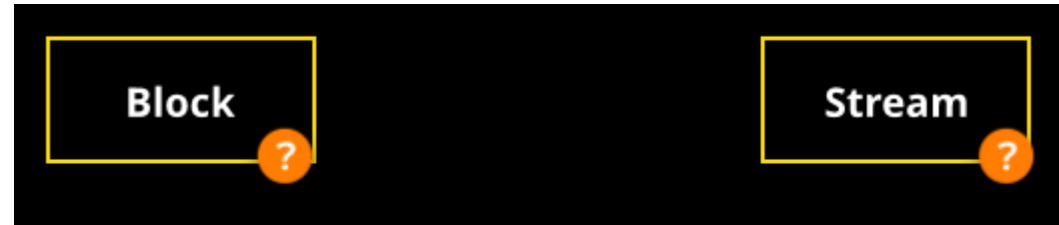


Para elegir entre cifradores por bloques o de flujo, primero debemos comprender dos propiedades:

La confusión dificulta establecer la relación entre la clave y el texto cifrado mediante transformaciones no lineales.

La difusión distribuye la influencia de cada bit del texto plano sobre múltiples bits del texto cifrado.

¿Cuándo utilizar cada tipo?



Los cifradores por bloques procesan fragmentos completos de datos de tamaño fijo.

Los cifradores de flujo procesan los datos de forma continua, normalmente bit a bit o byte a byte.

Ventajas y limitaciones

	Block	Stream
Advantages	• High diffusion • Immune to malicious injections	• Fast encryption • Low error propagation
Disadvantages	• Slow encryption • High error propagation	• Low diffusion • Susceptible to malicious injections

Algoritmos de cifrado simétrico

Algunos algoritmos de cifrado simétrico son:

- AES (Estándar de Cifrado Avanzado)
- DES (Estándar de Cifrado de Datos)
- IDEA (Algoritmo Internacional de Cifrado de Datos)
- Blowfish (alternativa histórica a DES o IDEA)
- RC4 (Rivest Cifrador 4)
- RC5 (Rivest Cifrador 5)
- RC6 (Rivest Cifrador 6)

AES, DES, IDEA, Blowfish, RC5 y RC6 son cifradores por bloques. RC4 es un cifrador de flujo.

Funciones hash

Una función hash recibe un archivo, mensaje u otra entrada y produce una cadena de longitud fija denominada resumen o hash.

Un hash no es texto cifrado y no se descifra. Las funciones hash contribuyen a verificar la integridad y, cuando se combinan con otros mecanismos, la autenticidad.

Funciones hash y cifradores

Los cifradores protegen datos que luego deben recuperarse. Una función hash opera en un solo sentido y se utiliza cuando no es necesario reconstruir la entrada original.

¿Cuándo no necesitamos recuperar el dato original?

Los sistemas no deberían almacenar contraseñas en texto plano. Deben guardar un hash derivado con sal y una función especializada. Durante la autenticación, el sistema compara la derivación de la contraseña ingresada con el valor almacenado.

Algoritmos hash

MD

Los algoritmos Message Digest generan resúmenes para verificar integridad. MD5 produce 128 bits, pero presenta colisiones conocidas y no debe utilizarse con fines de seguridad.

SHA

La familia SHA genera resúmenes de diferentes tamaños. SHA-1 produce 160 bits y está obsoleto para usos criptográficos. SHA-256 produce 256 bits y continúa ampliamente utilizado.

Colisiones

Una propiedad crítica de las funciones hash es su resistencia a colisiones.

Una colisión ocurre cuando dos entradas distintas producen el mismo hash.

Como una función hash transforma entradas de longitud variable en salidas de tamaño fijo, las colisiones son matemáticamente inevitables. Un algoritmo seguro debe hacerlas computacionalmente inviables.

Ejemplo

MD5 para «Hola, mi nombre es»:
3a4bgc4322ccc27y4o33485yuh341a25

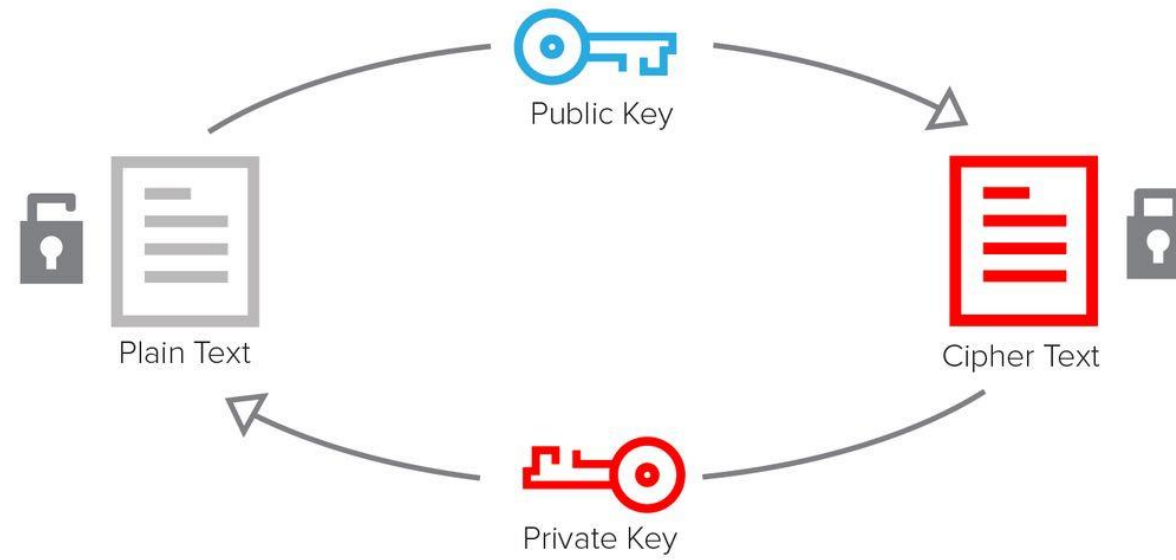
MD5 para «Hola, mi nombre es Justin»:
5t3d333ws229yn23v29f29cd901ue4db

MD5 para «12345»:
3a4bgc4322ccc27y4o33485yuh341a25

Algoritmos de cifrado

Calcular el hash de un archivo permite verificar que el contenido recibido coincide con el esperado:

- Descargas
- Comparación entre archivos enviados y recibidos
- Informática forense
 - Inicio de la respuesta a incidentes



Cifrado asimétrico

Introducción

Los algoritmos simétricos emplean la misma clave para cifrar y descifrar. Los algoritmos asimétricos utilizan un par de claves relacionadas: una pública y una privada.

Un caso de uso del cifrado asimétrico es el establecimiento seguro de claves.

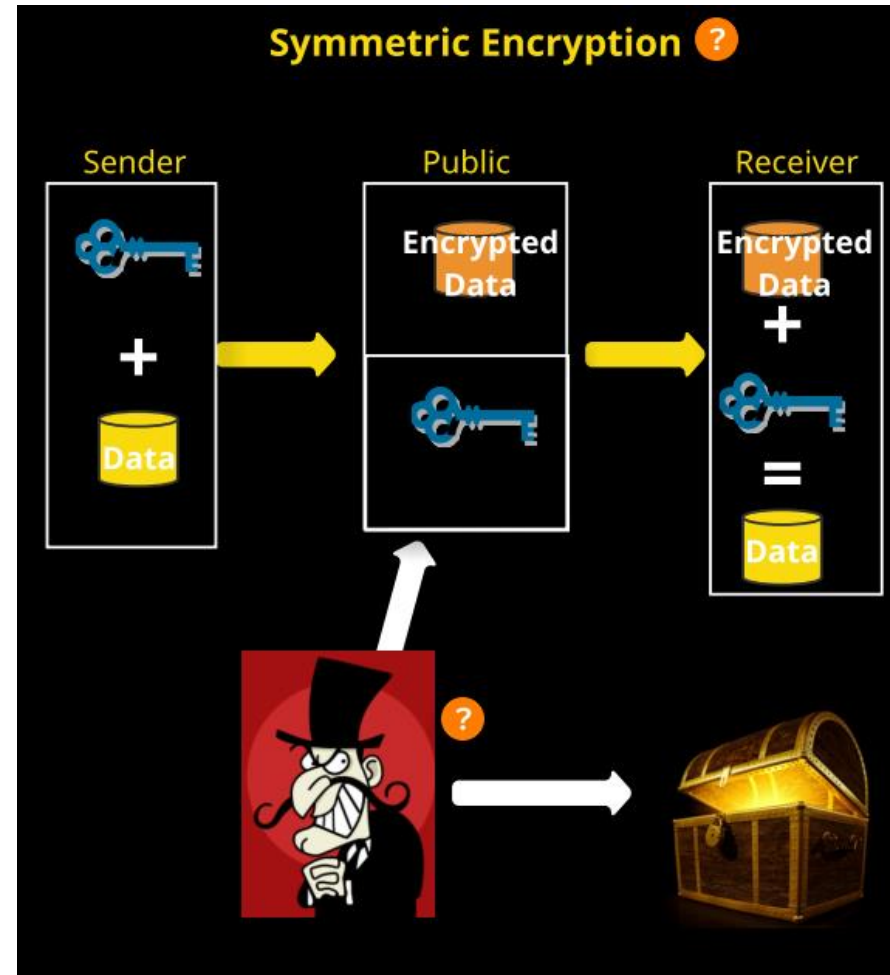
¿Por qué utilizamos cifrado asimétrico?

En el cifrado simétrico surge una pregunta central: ¿cómo compartir la clave que protegerá la comunicación?

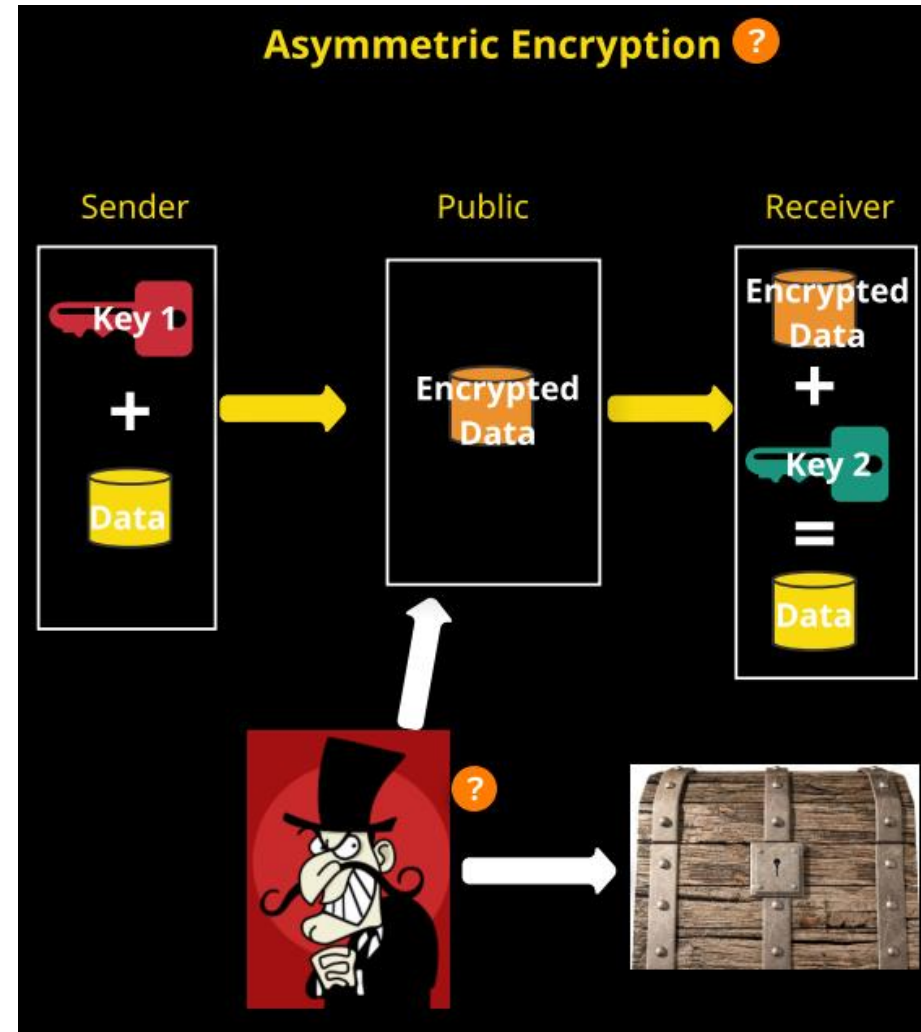
El problema del cifrado simétrico

Si enviamos la clave a través de una intranet o de Internet, un atacante podría interceptarla y utilizarla para descifrar los datos.

Intercambio de claves públicas



Intercambio de claves públicas





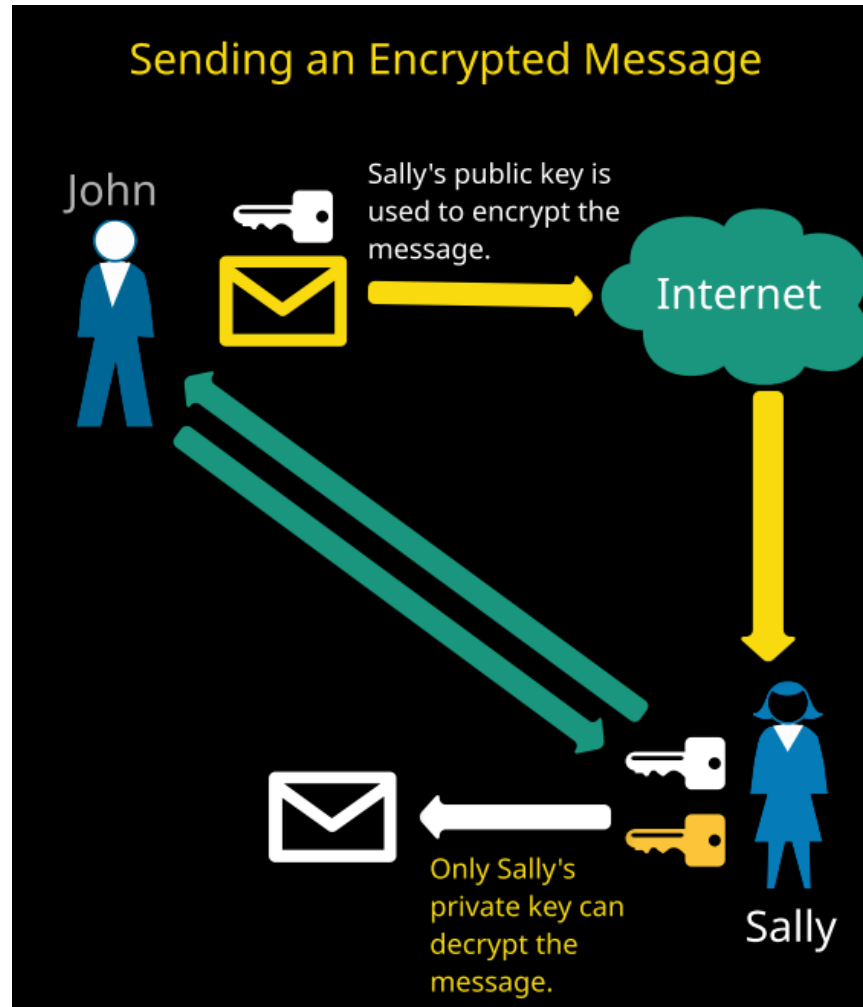
Infraestructura de clave pública

Intercambio de claves públicas

Panorama de PKI

- Utiliza criptografía asimétrica en las comunicaciones
- No corresponde a una tecnología única, sino a un marco de confianza
- Las autoridades de certificación (CA) emiten certificados
- Apoya la confidencialidad, autenticidad, integridad y el no repudio
 - **Confidencialidad:** Los datos se cifran durante el tránsito.
 - **Autenticidad:** Los certificados digitales permiten validar la identidad del emisor.
 - **Integridad:** La firma digital demuestra la posesión de la clave privada correspondiente.
 - **No repudio:** Las partes obtienen evidencia sobre la identidad y participación en la comunicación.

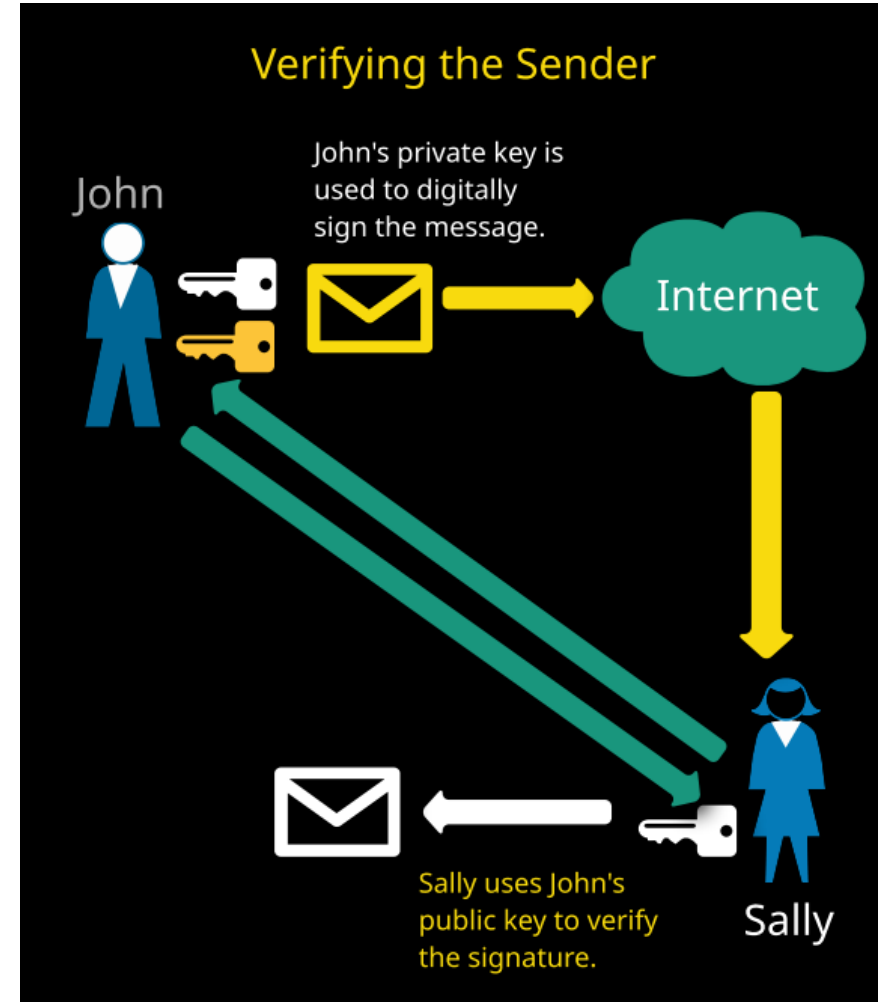
Intercambio de claves públicas



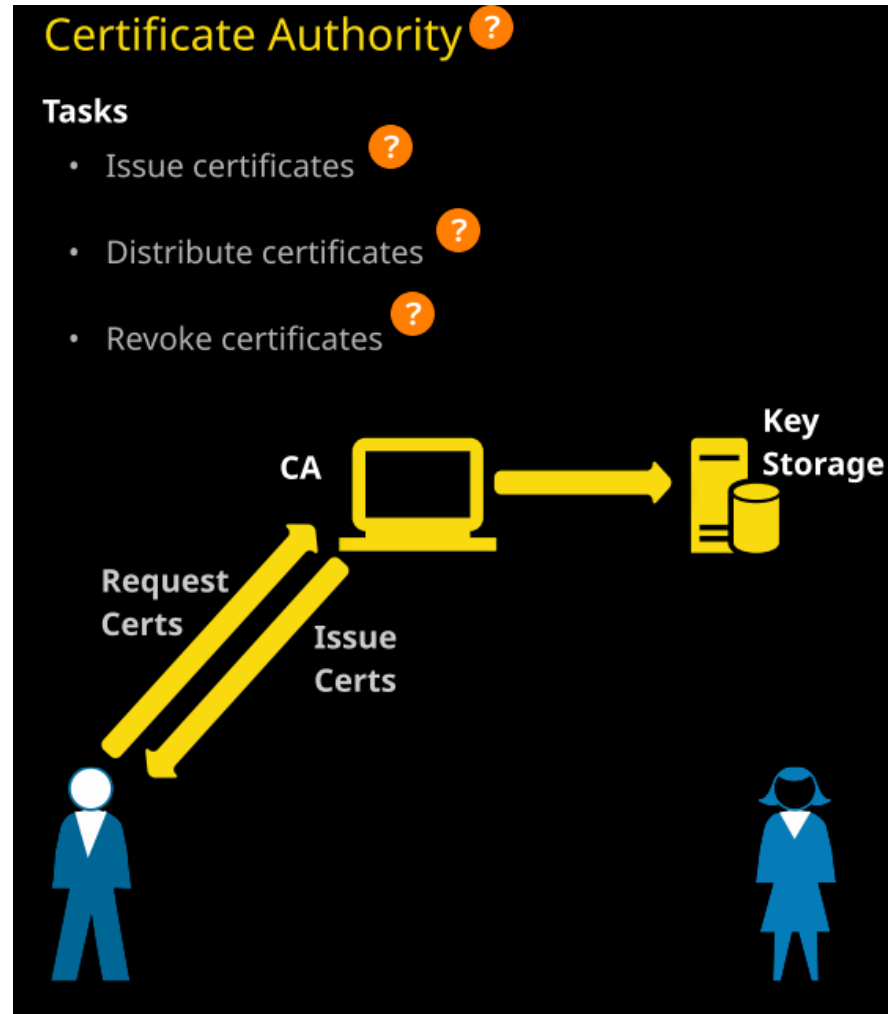
- **Confidencialidad:** Los datos se cifran durante el tránsito.

Intercambio de claves públicas

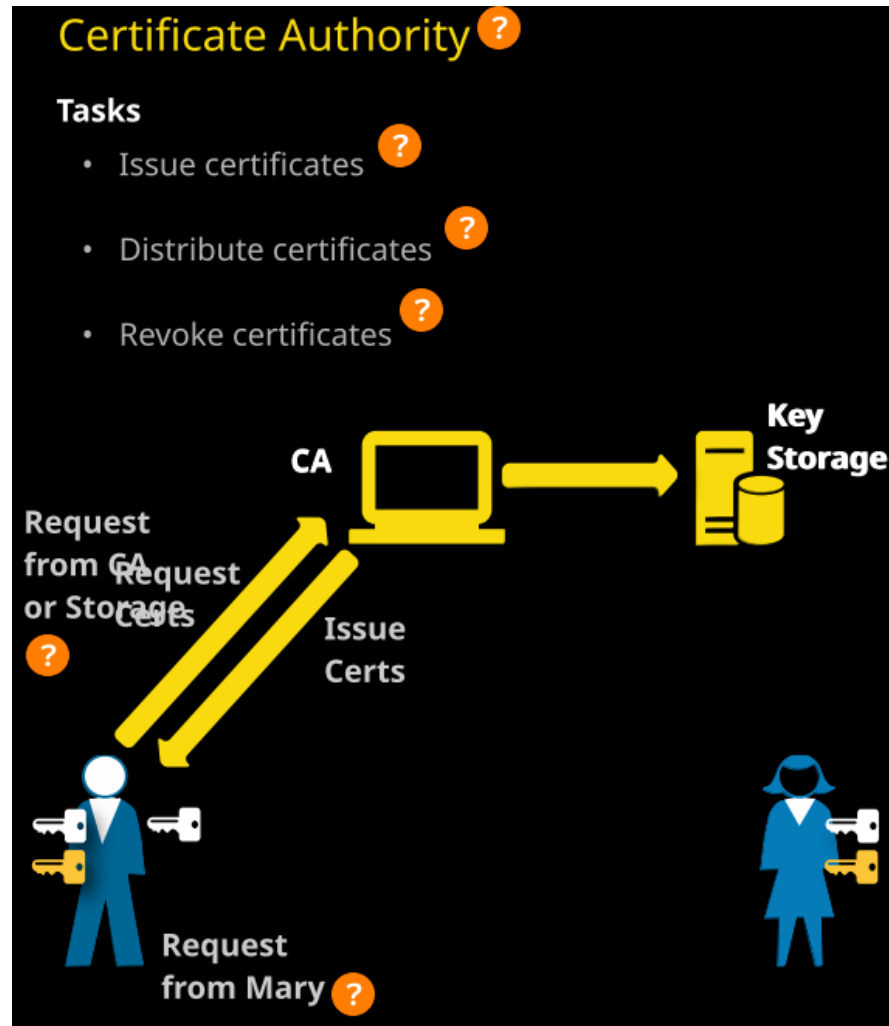
- **Autenticidad:** Los certificados digitales permiten validar la identidad del emisor.
- **Integridad:** La firma digital demuestra la posesión de la clave privada correspondiente.
- **No repudio:** Las partes obtienen evidencia sobre la identidad y participación en la comunicación.



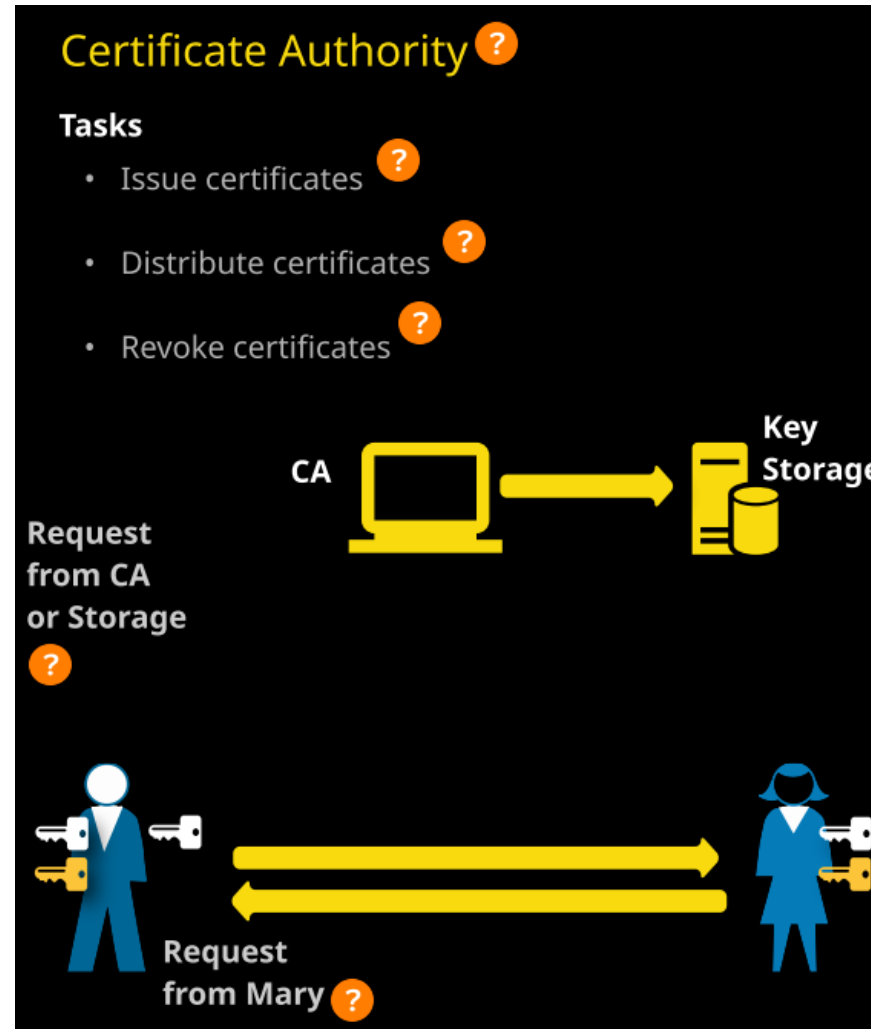
Intercambio de claves públicas



Intercambio de claves públicas



Intercambio de claves públicas

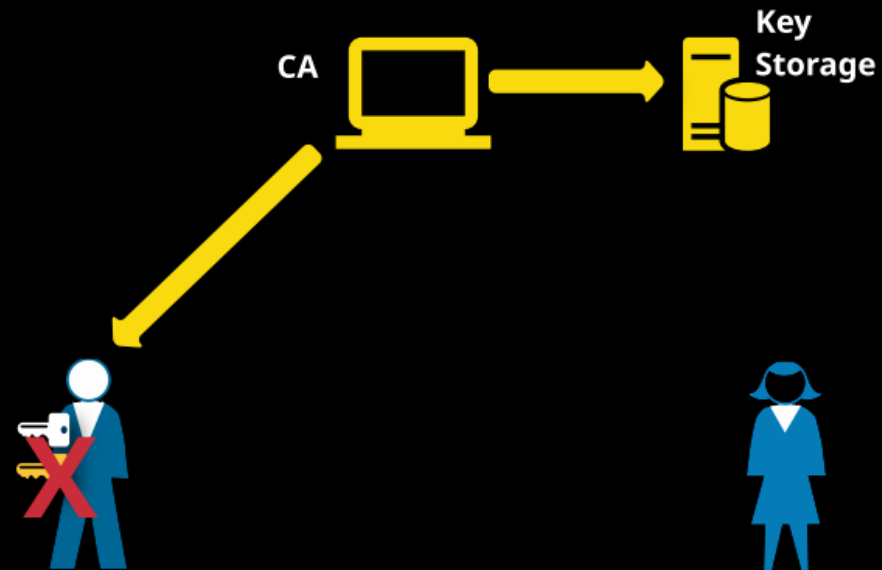


Intercambio de claves públicas

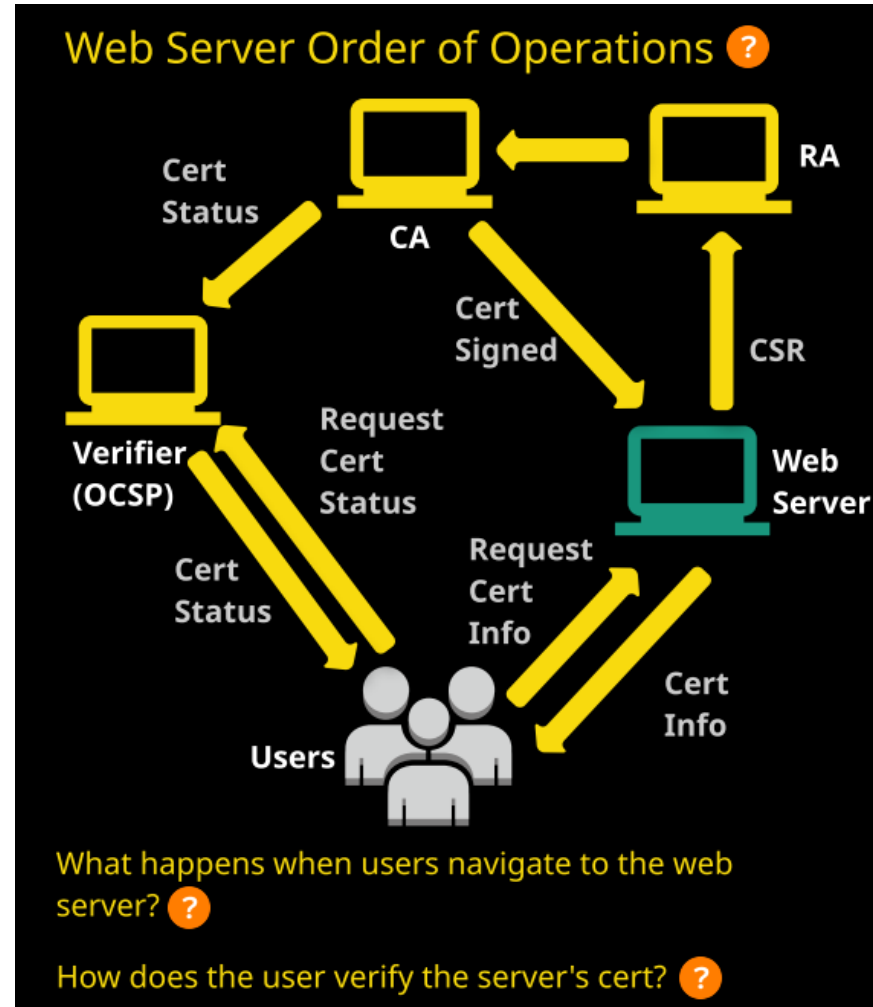
Certificate Authority ?

Tasks

- Issue certificates ?
- Distribute certificates ?
- Revoke certificates ?



Intercambio de claves públicas



Intercambio de claves públicas

Conceptos de PKI

Autoridad de certificación (CA): entidad confiable que emite, valida y revoca certificados digitales.

Lista de revocación de certificados (CRL): relación de certificados revocados antes de su fecha de expiración.

Solicitud de firma de certificado (CSR): petición que contiene la clave pública y los datos de identidad requeridos para que una CA emita un certificado.

Protocolo de estado de certificados en línea (OCSP): mecanismo para consultar el estado de revocación de un certificado mediante una respuesta del servicio OCSP.

Intercambio de claves públicas

Conceptos de PKI

Fijación de clave o certificado: asociación de una clave pública o certificado esperado con un servicio para reducir el riesgo de certificados fraudulentos.

Certificados digitales: estructuras firmadas que vinculan una identidad con una clave pública e incluyen información sobre su emisor y vigencia.

Custodia de claves: esquema de almacenamiento en el que un tercero autorizado puede acceder a las claves bajo condiciones definidas, por ejemplo para recuperación.

Intercambio de claves públicas

Conceptos de PKI

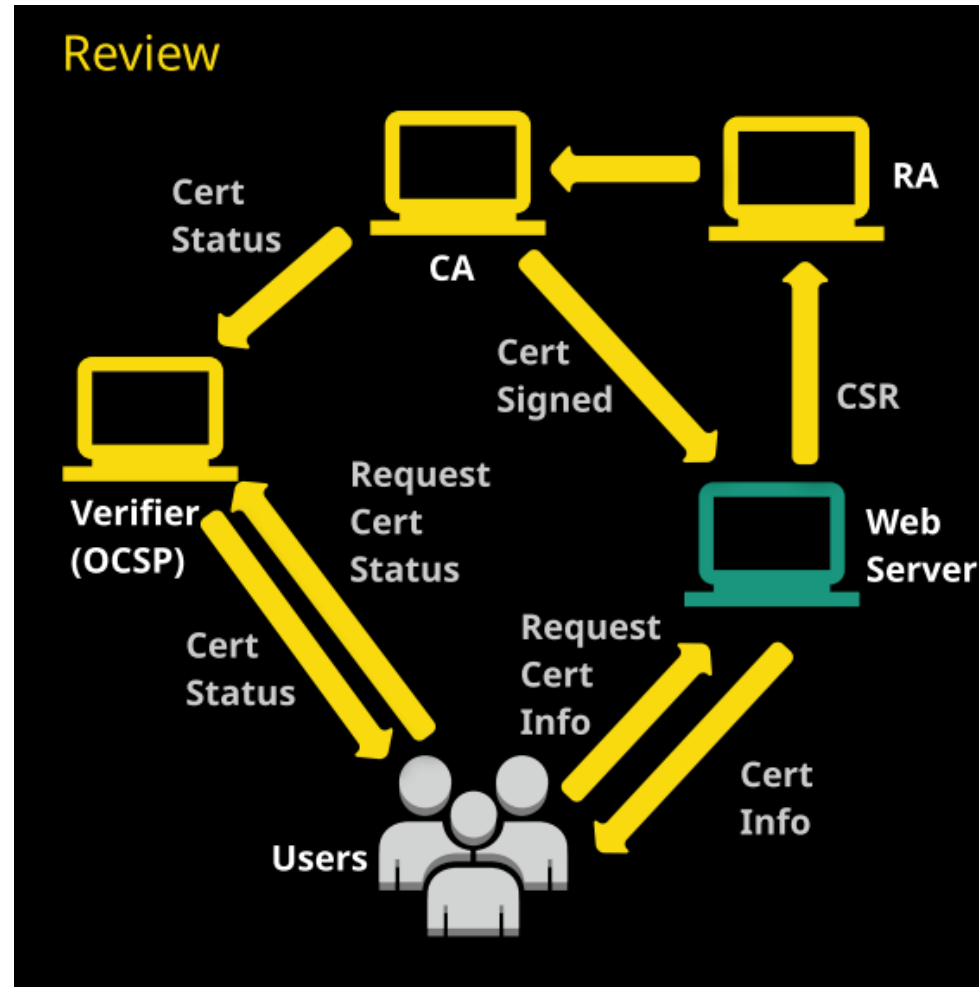
Cadena de certificados: secuencia ordenada desde el certificado de entidad final hasta una CA raíz de confianza. Cada certificado permite verificar la firma del siguiente nivel de la cadena.

OCSP stapling: técnica mediante la cual el servidor adjunta al protocolo TLS una respuesta OCSP vigente, evitando que cada cliente consulte directamente a la CA.



Intercambio de claves públicas

Intercambio de claves públicas



Intercambio de claves públicas

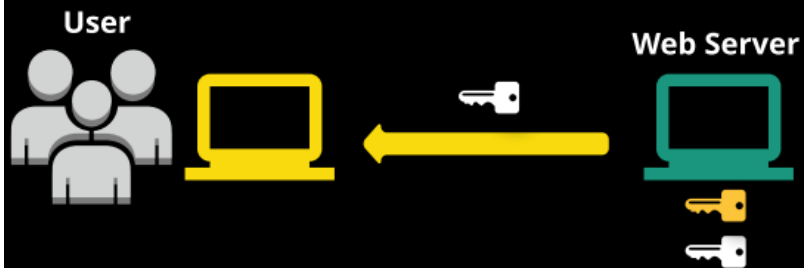
Public Key Exchange

To find out how a public key exchange works, let's talk about how SSL/TLS connections are established.

Step 1: ?

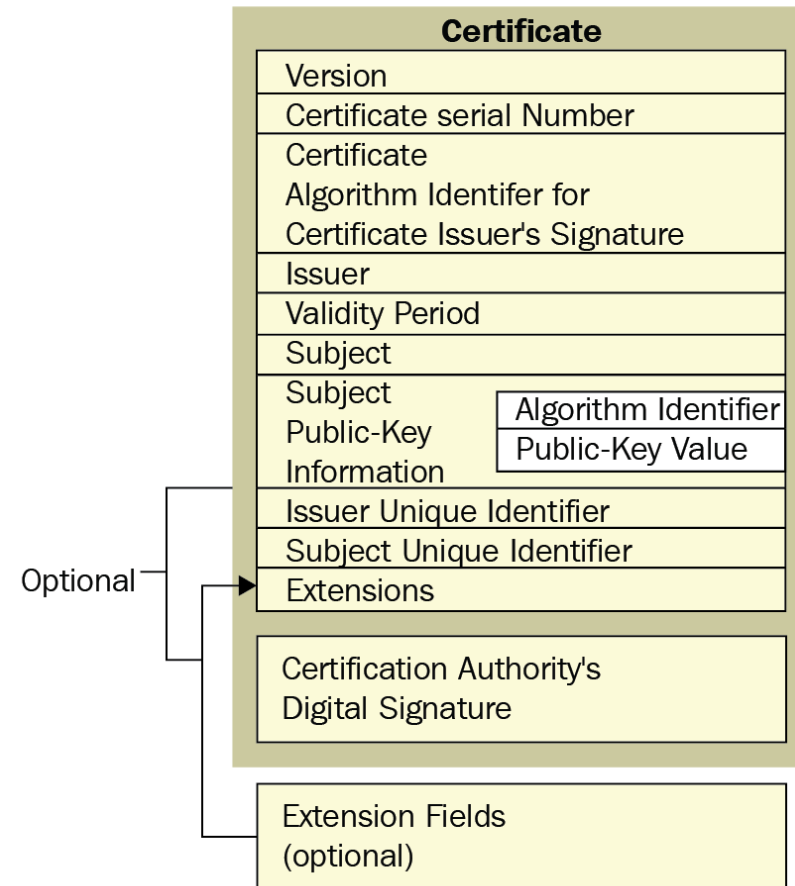


Step 2: ?



Intercambio de claves públicas

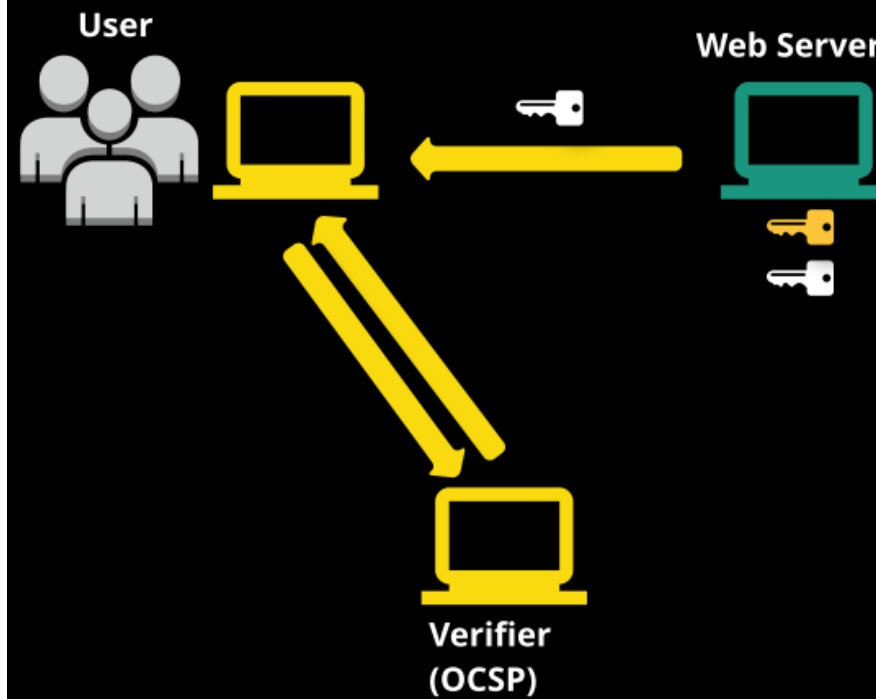
Standard X.509 certificate format



Intercambio de claves públicas

Public Key Exchange

Step 2A: ?



Intercambio de claves públicas

Public Key Exchange

Now that you (the user) have the server's public key, you can send encrypted data to the server. But what if the server needs to send data to you?

Step 3: ?



A symmetric session key is created by the user, encrypted with the server's public key, and sent back to the server.

Intercambio de claves públicas

Public Key Exchange

The results:

Asymmetric Key Exchange

Symmetric Data Exchange



Gracias